Table of Contents

Executive Summary
- About the 2024 OSSRA
- Overview

Open Source Vulnerabilities and Security
- Taking Action to Prevent Vulnerabilities from Entering...
- Eight of the Top 10 Vulnerabilities Can Be Traced Bac...
- Why Some BDSAs Don't Have CVEs
- Vulnerabilities by Industry

Open Source Licensing
- Understanding License Risk
- Protection Against Security and IP Compliance Risk I...

Operational Factors Affecting Open Source Risk
- Open Source Consumers Need to Improve Maintena...

Findings and Recommendations
- Creating a Secure Software Development Framework
- Knowing What's in Your Code
- Terminology
- Contributors

Download PDF

Executive Summary

This report offers recommendations to help creators and consumers of open source software manage it responsibly, especially in the context of securing the software supply chain. Whether a consumer or provider of software, you are part of the software supply chain, and need to safeguard the applications you use from upstream as well as downstream risk. In the following pages, we examine

- Persistent open source security concerns
- Why developers need to improve at keeping open source components up-to-date
- The need for a Software Bill of Materials (SBOM) for software supply chain management
- How to protect against the security and IP compliance risk introduced by AI coding tools

For nearly a decade, the major theme of the “Open Source Security and Risk Analysis” (OSSRA) report has been *Do you know what’s in your code?* In 2024, it’s a question more important than ever before. With the prevalence of open source and the rise in AI-generated

and the rise in AI generated code, more and more applications are now built with third-party code.

Without a complete view of what's in your code, neither you, your vendors, nor your end users can be confident about what risks your software may contain. Securing the software supply chain begins with knowing what open source components are in your code, as well as identifying their respective licenses, code quality, and potential vulnerabilities.

About the 2024 OSSRA

In this, its ninth edition, the 2024 OSSRA report delivers an in-depth look at the current state of open source security, compliance, licensing, and code quality risks in commercial software. The...

Continue Reading

Open Source Vulnerabilities and Security

Of the 1,067 codebases analyzed by the Black Duck Audit Services team and used as the base data for this year's OSSRA report, 96% contained open source. Seventy-seven percent of all the source code and files scanned originated from open source code.

The average number of open source components in a given application this year was 526—a practical example of the importance if not absolute necessity for automated security testing. Manual testing, which might be feasible for a small number of components, becomes virtually impossible at

scale and requires the use of an automated solution like software composition analysis (SCA). Unlike manual testing, automated security tests can be executed quickly and consistently, allowing developers...

Continue Reading

Open Source Licensing

Effective software supply chain management requires licensing as well as security compliance. You're using open source components and libraries to build software and know those components are governed by open source licenses, but do you know those licenses' details? Even one noncompliant license in your software can result in legal issues, loss of lucrative intellectual property, time-consuming remediation efforts, and delays in getting your product to market.

The Black Duck Audit Services team found that over half—53%—of the 2023 audited codebases contained open source with license conflicts...

Continue Reading

Operational Factors Affecting Open Source Risk

Ideally, open source consumers use only components supported by robust communities. Linux, for example, is improved every day by thousands of developers from hundreds of organizations. However, of the 936 codebases examined by the Black Duck Audit Services team that included risk assessments, 49% contained open source that had no new development in the last two years. If a project is no longer being maintained—

longer being maintained especially in the case of smaller projects—there have been no feature upgrades, no code improvements, and no discovered security problems fixed.

It's not an uncommon issue with open source projects. According to some reports, nearly 20% of Java and JavaScript open source projects that were being maintained in 2022 are no longer being maintained in 2023, opening those projects to vulnerabilities and exploits. Open source is largely the product of volunteer contributors and maintainers. While some...

Continue Reading

Findings and Recommendations

Whether a single developer or a large company, everyone has a responsibility to maintain software supply chain security practices in order to mitigate risks. As the number of software supply chain attacks grows, effectively managing open source usage, components, and dependencies becomes even more critical to managing risk. Organizations that include open source in their products—which, as this report demonstrates, is literally all organizations—should proactively manage open source risks as a part of their secure software development practices.

"Securing the Software Supply Chain: Recommended Practices for Managing Open Source Software and Software Bill of Materials," published by the United States Cybersecurity and Infrastructure Security Agency in late 2023, provides detailed guidelines for the use of open source in the software supply chain, including...

Continue

Continue

Reading